بِسْمِ اللّٰهِ الرَّحْمٰنِ الرَّحِيْمِ

اَلْحَمْدُ لِلّٰهِ رَبِّ الْعَالَمِيْنَ

وَالصَّلٰوةُ وَالسَّلَامُ عَلٰى خَاتَمِ النَّبِيِّيْنَ

Computer Security: Principles and Practice. Fourth Edition
By: William Stallings and Lawrie Brown
Chapter 7

Denial-of-Service Attacks

Denial-of-Service (DoS) Attack

"An action that prevents or impairs the authorized use of networks, systems, or applications by exhausting **resources** such as central processing units (**CPU**), **memory**, **bandwidth**, and **disk space**."

Denial-of-Service (DoS)

- A form of attack on the **availability** of some service
- **Categories** of **resources** that could be attacked are:

Network bandwidth

Relates to the capacity of the network links connecting a server to the Internet

For most organizations this is their connection to their Internet Service Provider (ISP)

System resources

Aims to overload or crash the network handling software

Application resources

Typically involves a number of valid requests, each of which consumes significant resources, thus limiting the ability of the server to respond to requests from other users

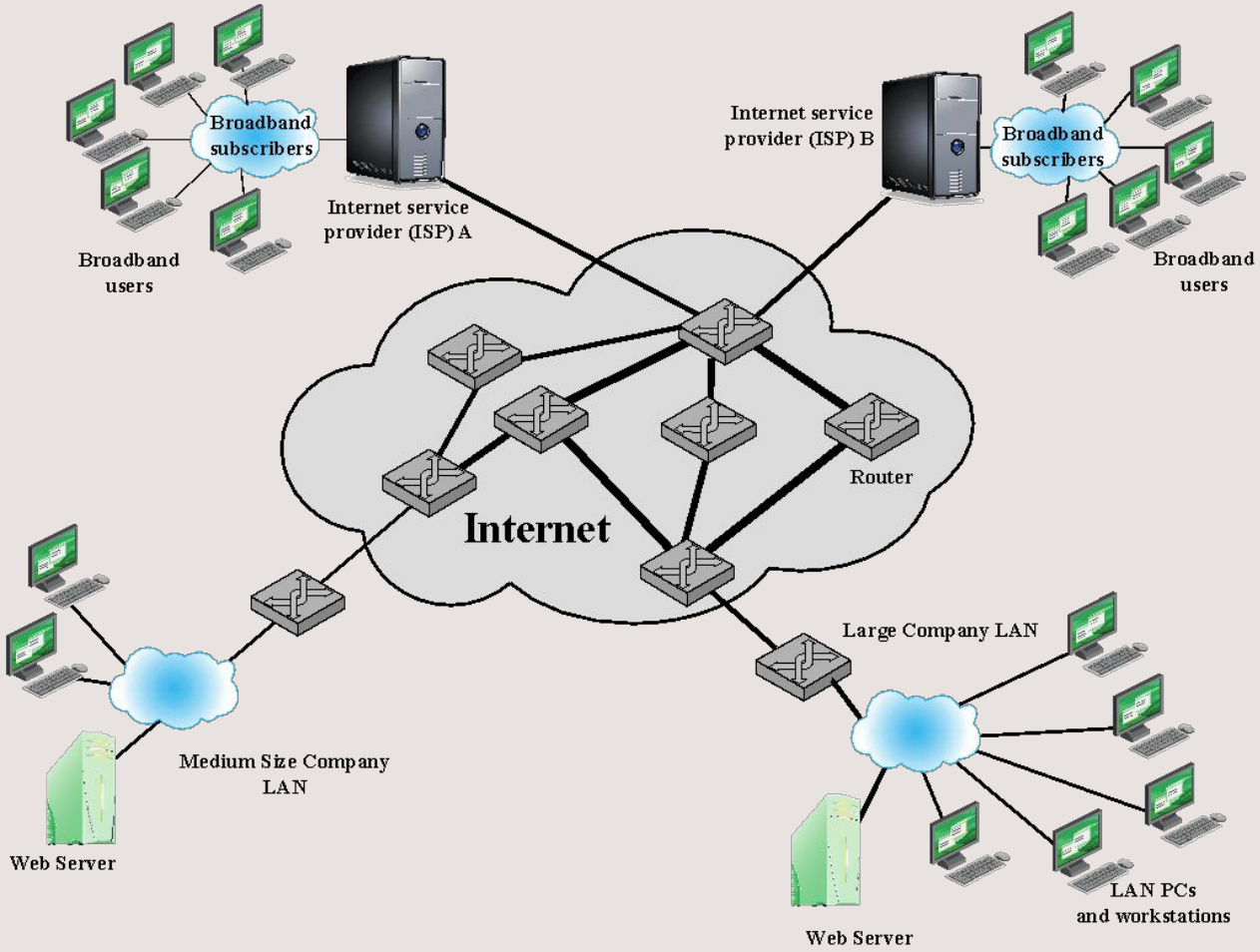
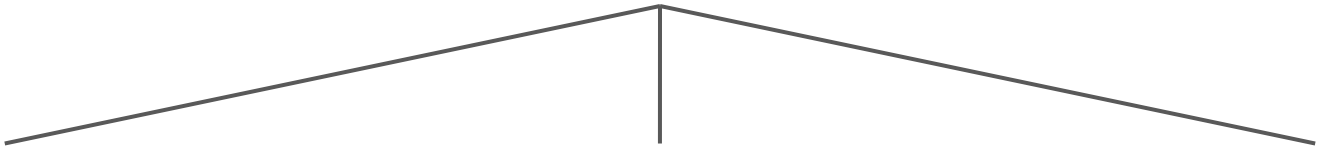


Figure 7.1 Example Network to Illustrate DoS Attacks

Denial-of-Service (Categories)



Network Flooding

Bulk (overwhelming number of) requests sent aiming to choke the target network (usually their ISP link) The requests can be for any protocol and **can be invalid**

System Attack

Rather **smaller volume** of traffic **carefully designed** to overload or crash the system resources exploiting a network handling vulnerability in the **system**

Application Attack

Smaller volume of traffic **carefully designed** valid packets aimed to exhaust application specific system resources exploiting an **application mechanism/vulnerability**

Distributed Denial of Service (DDoS) Attacks

Use of **multiple systems** to generate attacks

Attacker uses a flaw in operating system or in a common application to gain access and installs their program on it (**zombie**)

Large collections of such systems under the control of one attacker's control can be created, forming a **botnet**

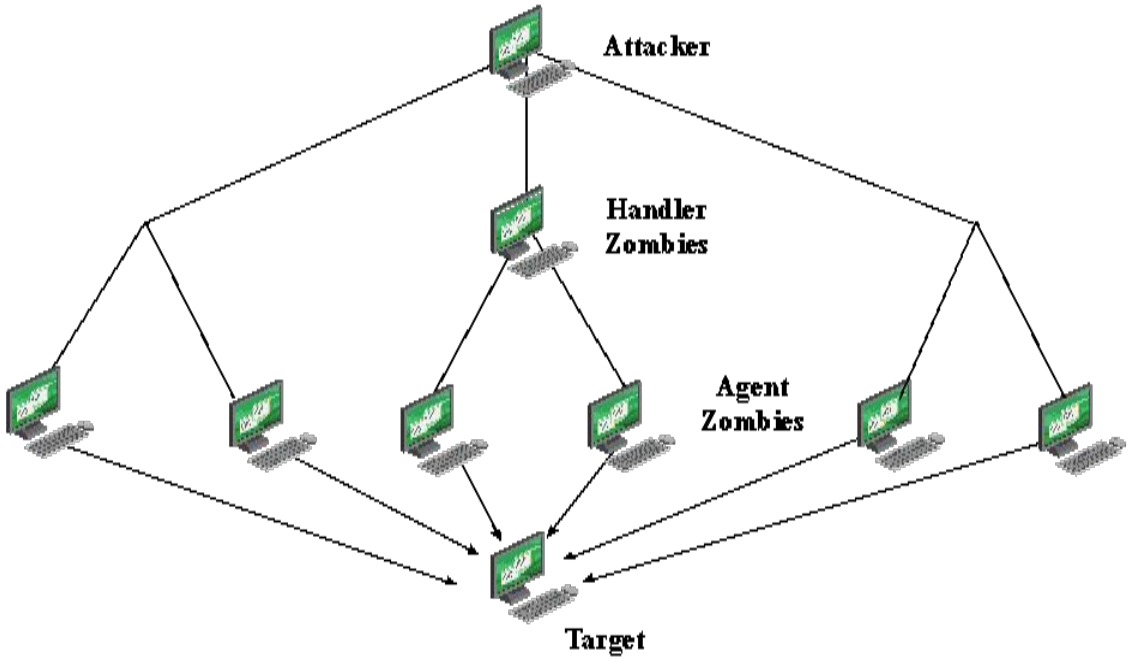


Figure 7.4 DDoS Attack Architecture

Flooding Attacks (choking network)

Usually aiming the ISP link as that's usually the bottleneck

- Classified based on network protocol used
- Intent is to overload the network capacity on some link to a server
- Virtually any type of network packet can be used

ICMP flood	• **Ping flood using ICMP echo request packets** • **Traditionally network administrators allow such packets into their networks because ping is a useful network diagnostic tool**
UDP flood	• **Uses UDP packets directed to some port number on the target system. (any port number just to overwhelm)**
TCP flood	• **Sends TCP packets to the target system** • **Total volume of packets is the aim of the attack rather than the system code**

ICMP Flood (Classic DoS Attack)

Flooding ping command

- Aim of this attack is to **overwhelm** the capacity of the **network** connection to the target organization (*Even if the target does not respond, the goal is already achieved*)
- Traffic can be handled by higher capacity links on the path, but packets are discarded as capacity decreases
- Source of the attack is clearly identified unless a spoofed address is used
- Network performance is noticeably affected

UDP, TCP Flood

UDP Flood

A common choice is large amounts of packets directed at the **UDP diagnostic echo service**, commonly enabled on many server systems by default.

TCP Flood

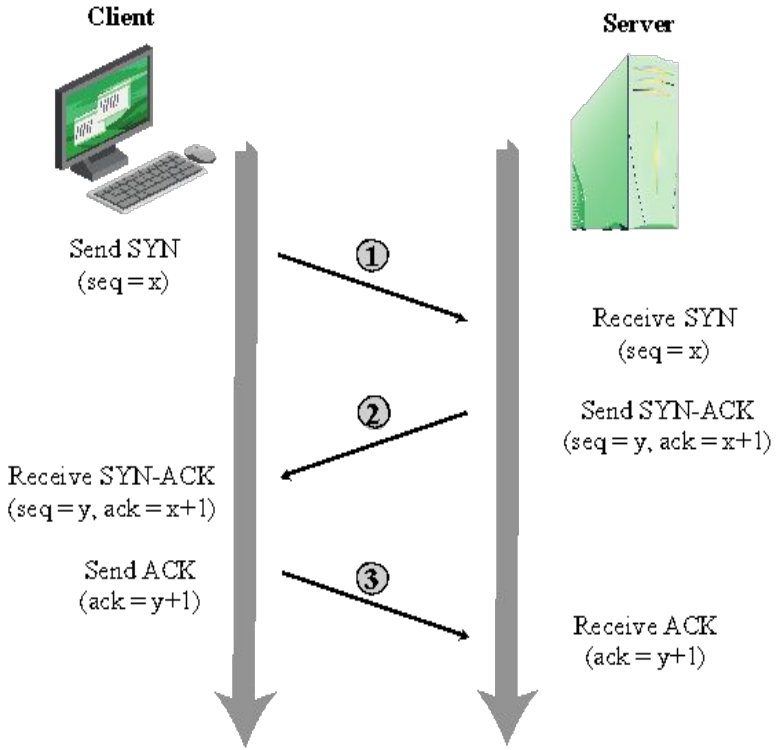
- Huge volume of **TCP syn packets** just aimed at choking the network links to the server
- This attack could also use **TCP data packets without a connection**, which would be rejected by the server as not belonging to any known connection. But by this time the attack has already succeeded in flooding the links to the server.

HTTP Flood

- **Attack that bombards Web servers with HTTP requests**
- **Huge volume** of requests aimed at **choking the network**
- Consumes considerable resources
- **Spidering**
  - Bots starting from a given HTTP link and following all links on the provided Web site in a recursive way

Source Address Spoofing

- **Use forged source addresses**
  - Usually via the raw socket interface on operating systems
  - Makes attacking systems harder to identify
- Attacker generates large volumes of packets that have the target system as the destination address
- Congestion would result in the router connected to the final, lower capacity link
- Requires network engineers to specifically query flow information from their routers
- ***Backscatter traffic*: Replies towards the fake spoofed addresses routed across internet**



When a TCP client system initiates the request for a TCP connection by sending a SYN packet to the server it contains the client's address and port number and supplies an initial sequence number. It may also include a request for other TCP options.

The server records all the details about this request in a table of known TCP connections. It then responds to the client with a SYN-ACK packet.

Figure 7.2 TCP Three-Way Connection Handshake

SYN Spoofing (Attacking System)

- Sending TCP syns for **connection requests** from multiple fake IPs
- Attacks the ability of a server to respond to future connection requests by **overflowing the tables used to manage them** Thus legitimate users are denied access to the server
- Hence an attack on **system resource**s, specifically the network handling code in the operating system
- **Effective even with smaller volume of traffic compared to flooding**
- Different from syn flooding as in that case, total volume of packets is high aiming to attack network rather than the system code.

The attacker generates a number of SYN connection request packets with forged source addresses. For each of these the server records the details of the TCP connection request and sends the SYN-ACK packet to the claimed source address. If there is a valid system at this address, it will respond with a RST (reset) packet to cancel this unknown connection request. When the server receives this packet, it cancels the connection request and removes the saved information.

However, if there is no system at the forged address, then no reply will return. In these cases the server will resend the SYN-ACK packet a number of times before finally assuming the connection request has failed and deleting the information saved concerning it.

In this period between when the original SYN packet is received and when the server assumes the request has failed, the server is using an entry in its table of known TCP connections. This table is typically sized on the assumption that most connection requests quickly succeed and that a reasonable number of requests may be handled simultaneously.

However, in a SYN spoofing attack, the attacker directs a very large number of forged connection requests at the targeted server. These rapidly fill the table of known TCP connections on the server. Once this table is full, any future requests, are rejected. The server will be effectively cut off from the Internet, unable to respond to most legitimate connection requests.

There is a significant difference in the volume of network traffic between a SYN spoof attack and the basic flooding attack we discussed. The actual volume of SYN traffic can be comparatively low, nowhere near the maximum capacity of the link to the server. **It simply has to be high enough to keep the known TCP connections table filled.**

SIP flood attack (Application)

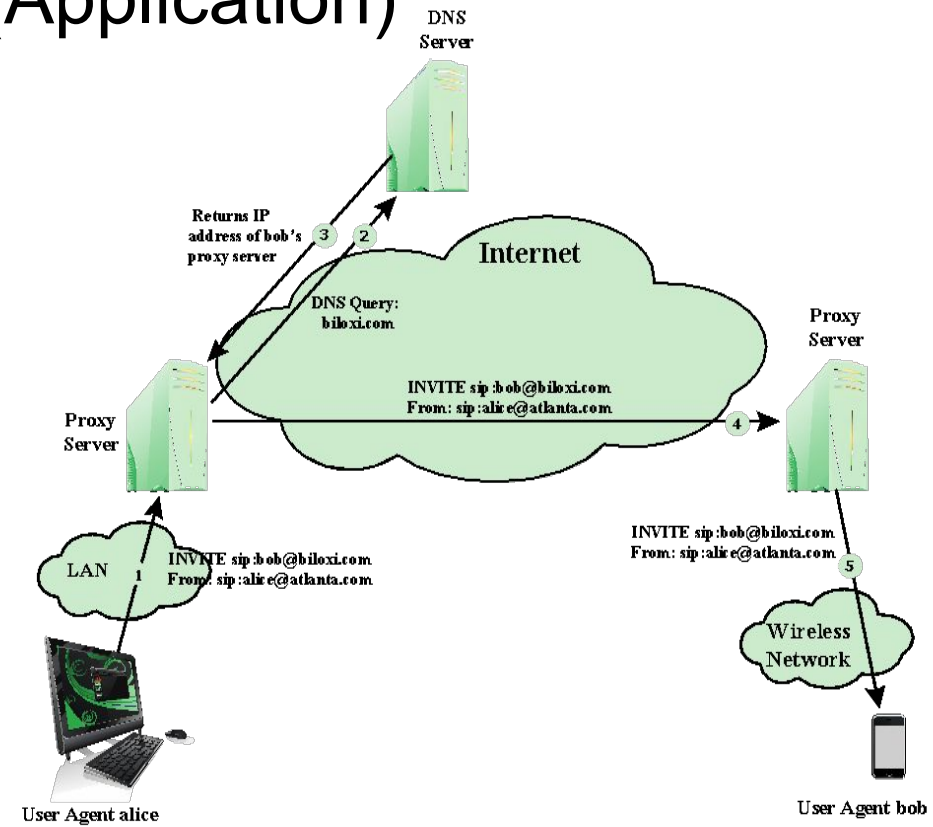


Figure 7.5 SIP INVITE Scenario

Session Initiation Protocol (SIP) is used for call setup in Voice over IP (VoIP). SIP messages signal end to end call setup (IP mapping, ringing and connection establishment) before data transfer over Real-time Transport Protocol (RTP) at transport layer

A SIP flood attack exploits the fact that a single INVITE request triggers considerable resource consumption.

The attacker can flood a SIP proxy with numerous INVITE requests with spoofed IP addresses.

This attack puts a load on the SIP proxy servers in two ways. First, their server resources are depleted in processing the INVITE requests. Second, their network capacity is consumed.

Call receivers are also victims of this attack. A target system will be flooded with forged VoIP calls, making the system unavailable for legitimate incoming calls.

HTTP Slowloris

- Operating systems and browsers commonly open **several parallel connections** to the same server (by **changing the source port** for each socket) to improve performance (max allowed depend on system and browser)
- Web servers assign a **thread or a process per TCP connection**
- Slowloris intentionally opens **many separate TCP connections**, sending one incomplete HTTP request per TCP connection, very slowly.
- Attacker keeps sending small requests slowly on each connection in order to **avoid connection timeout**
- By keeping many TCP connections "half-alive," Slowloris **uses up all available server threads/sockets.**
- **Hard to detect** as might be due to slow internet connection at client
- Existing intrusion detection and prevention solutions that rely on signatures to detect attacks will generally not recognize Slowloris

Hypertext Transfer Protocol (HTTP) Based Attacks

HTTP flood

- **Attack that bombards Web servers with HTTP requests**
- Consumes considerable resources
- **Spidering**
  - Bots starting from a given HTTP link and following all links on the provided Web site in a recursive way

Slowloris

- **Attempts to monopolize by sending HTTP requests that never complete**
- Eventually consumes Web server's connection capacity
- Utilizes legitimate HTTP traffic
- Existing intrusion detection and prevention solutions that rely on signatures to detect attacks will generally not recognize Slowloris

Reflection Attacks

- Attacker sends packets **to a known service on the intermediary** with a **spoofed source address of the actual target system**
- When intermediary responds, the response is sent to the target
- "Reflects" the attack off the intermediary (reflector)
- Goal is to generate enough volumes of packets to flood the link to the target system without alerting the intermediary
- The basic defense against these attacks is blocking spoofed-source packets

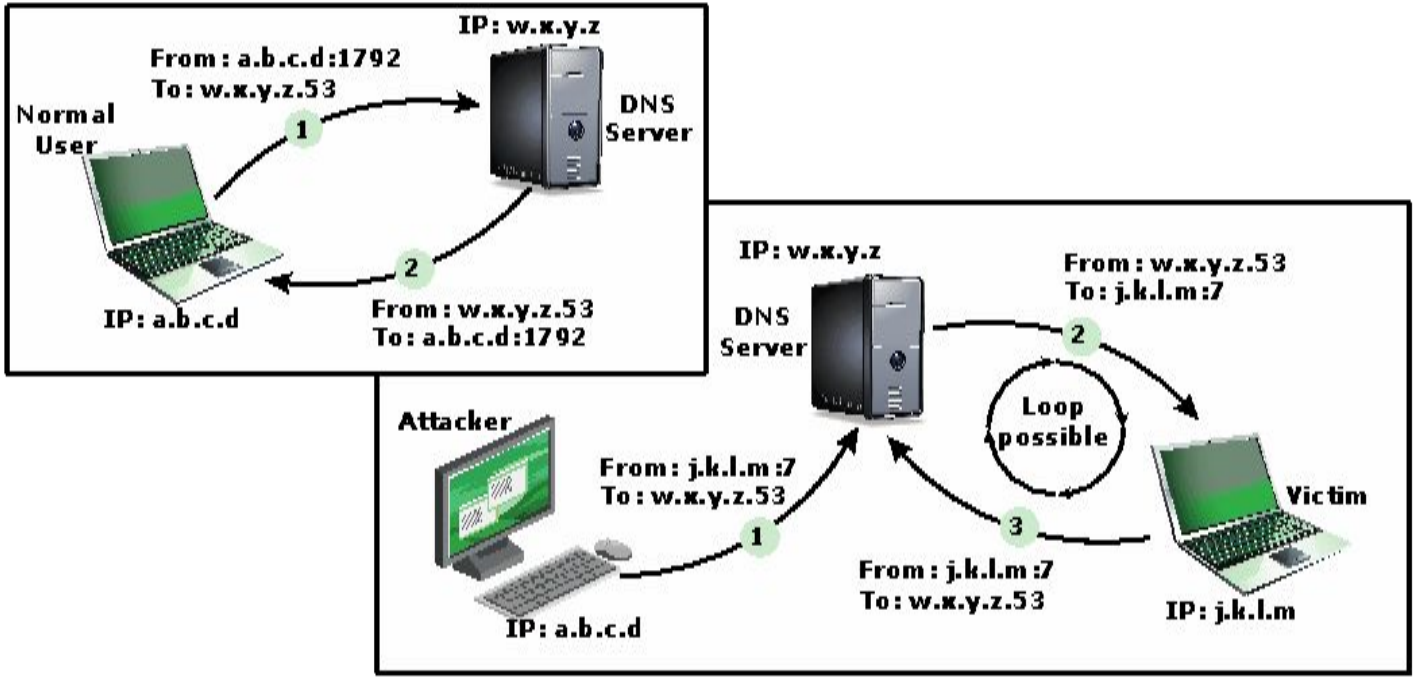


Figure 7.6 DNS Reflection Attack

The attacker sends a query to the DNS server with a spoofed IP source address of j.k.l.m; this is the IP address of the target. The attacker uses port 7, which is usually associated with echo, a reflector service. The DNS server then sends a response to the victim of the attack, j.k.l.m, addressed to port 7. If the victim is offering the echo service, it may create a packet that echoes the received data back to the DNS server. This can cause a loop between the DNS server and the victim if the DNS server responds to the packets sent by the victim.

Amplification Attacks

Type of Reflection attack:

Spoofed requests sent to intermediaries with **target's IP as source** and targeting a **network broadcast address as destination**

Amplifies attack: One request generates multiple responses:

Common attack methods:

- **ICMP echo request**
- **UDP echo service**

TCP services not usable due to connection-oriented nature.

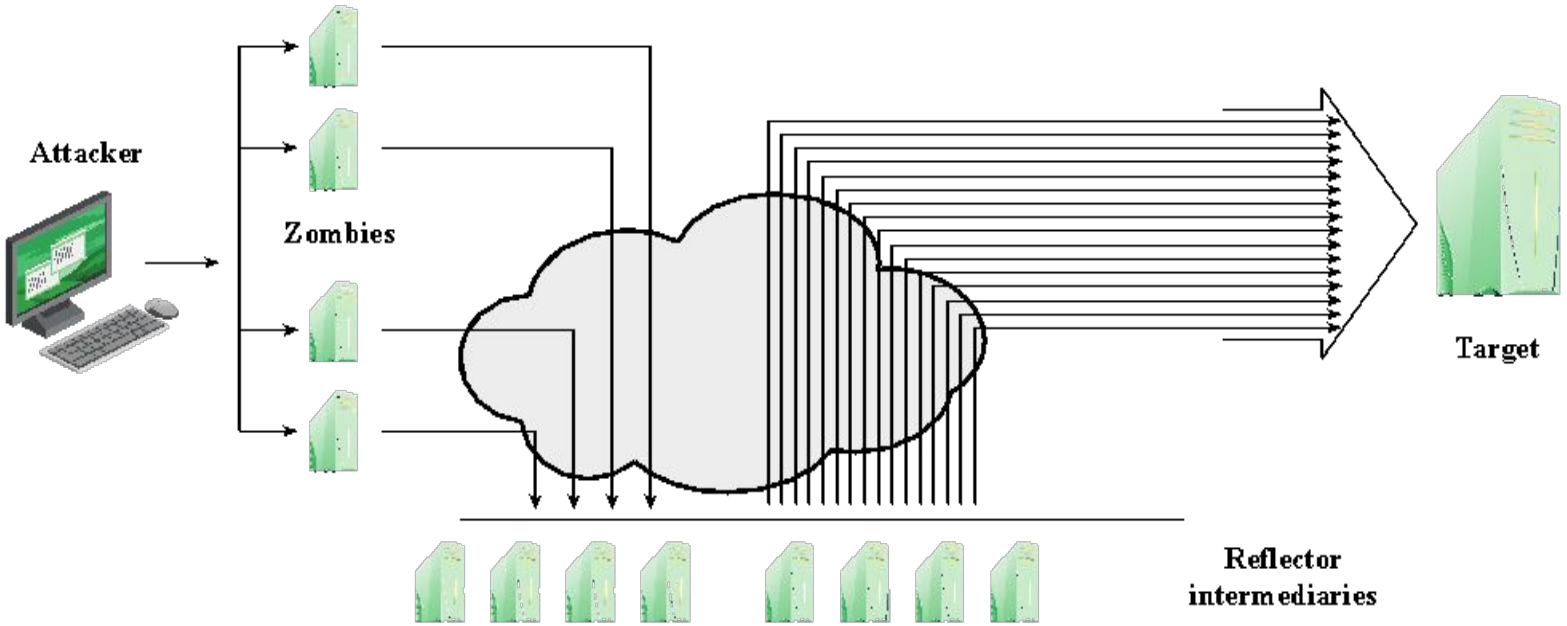


Figure 7.7 Amplification Attack

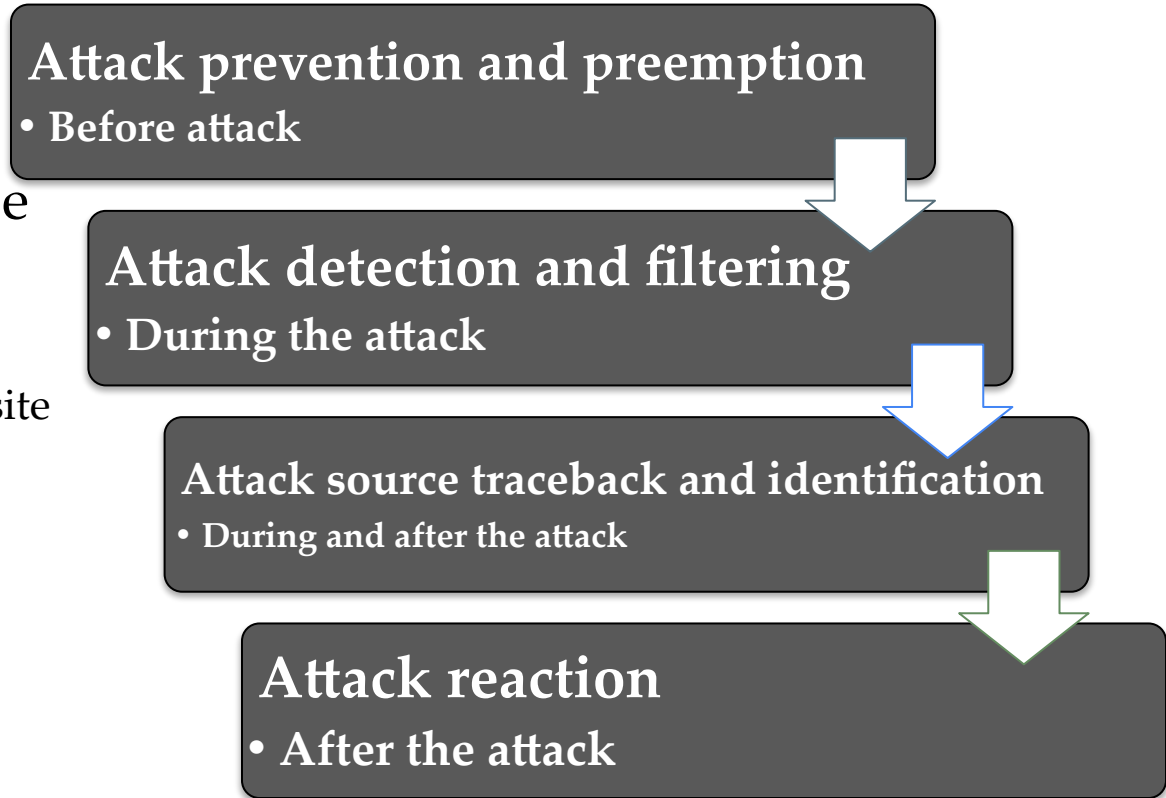
DNS Amplification Attacks

- Use packets directed at a legitimate DNS server as the intermediary system
- Attacker creates a series of DNS requests containing the spoofed source address of the target system
- **Exploit DNS behavior to convert a small request to a much larger response (amplification)**
- Target is flooded with responses
- Basic defense against this attack is to prevent the use of spoofed source addresses

DoS Attack Defenses

- These attacks **cannot be prevented entirely**
- High traffic volumes may be **legitimate**
  - High publicity about a specific site
  - Activity on a very popular site
  - Described as *slashdotted, flash crowd, or flash event*

Four lines of defense against DDoS attacks



DoS Attack Prevention

- **Block spoofed source addresses**
  - On routers as close to source as possible e.g. by **reverse path route check**
- **Filters may be used to ensure path back to the claimed source address is the one being used by the current packet**
  - Filters must be applied to traffic before it leaves the ISP's network or at the point of entry to their network
- **Use modified TCP connection handling code**
  - **Encode** critical information in a cookie that is sent as the server's initial sequence number
    - Legitimate client responds with an ACK packet containing the incremented sequence number cookie
  - **Drop** an entry for an incomplete connection from the TCP connections table when it overflows

DoS Attack Prevention

- **Block IP directed broadcasts**
- **Block suspicious services** and combinations
- Manage application attacks with a form of **graphical puzzle (captcha)** to distinguish legitimate human requests
- Good general system security practices
- Use **mirrored and replicated servers** when high-performance and reliability is required

Responding to DoS Attacks

Good Incident Response Plan

- Details on how to contact technical personal for ISP
- Needed to impose traffic filtering upstream
- Details of how to respond to the attack

- Antispoofing, directed broadcast, and rate limiting filters should have been implemented
- Ideally have network monitors and IDS to detect and notify abnormal traffic patterns

Responding to DoS Attacks

- **Identify type of attack**
  - Capture and analyze packets
  - Design filters to block attack traffic upstream
  - Or identify and correct system/application bug
- **Have ISP trace packet flow back to source**
  - May be difficult and time consuming
  - Necessary if planning legal action
- **Implement contingency plan**
  - Switch to alternate backup servers
  - Commission new servers at a new site with new addresses
- **Update incident response plan**
  - Analyze the attack and the response for future handling

Summary

- Denial-of-service attacks
  - The nature of denial-of-service attacks
  - Classic denial-of-service attacks
  - Source address spoofing
  - SYN spoofing
- Flooding attacks
  - ICMP flood
  - UDP flood
  - TCP SYN flood
- Defenses against denial-of-service attacks
- Responding to a denial-of-service attack
- Distributed denial-of-service attacks
- Application-based bandwidth attacks
  - SIP flood
  - HTTP-based attacks
- Reflector and amplifier attacks
  - Reflection attacks
  - Amplification attacks
  - DNS amplification attacks